

БАЗЫ ДАННЫХ для хакеров

Независимый доклад от CryptoJones

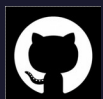
45 минут* • Диплом не требуется



Aaron K. Clark

Аспирант, Eastern University*

cryptojones@owasp.org



github.com/CryptoJones



CryptoJones@infosec.exchange

Каждая утечка, о которой вы
когда-либо читали, заканчивается в
БАЗЕ ДАННЫХ*

Главное сокровище



- ▶ Не ваше одностороничное приложение.
- ▶ Не ваш фаервол.
- ▶ Не ваши микросервисы.
- ▶ ДАННЫЕ. Всегда данные.

Что такое база данных?

Организованное хранилище + способ задавать вопросы.

Вот и всё. Остальное — детали.

- ▶ Картотека = хранилище + ваши глаза в роли запроса.
- ▶ Excel + Ctrl-F = хранилище + поиск-и-замена в роли запроса.
- ▶ Настоящая БД добавляет: масштаб, скорость, параллелизм, формальный язык.

Шесть слов, которые вам нужны

ТАБЛИЦА

■ вкладка электронной таблицы

СТРОКА

■ одна запись (один клиент, одно оповещение)

СТОЛБЕЦ

■ один атрибут (email, IP, итог)

ЗАПРОС

■ вопрос, который вы задаёте

СХЕМА

■ форма данных

ИНДЕКС

■ закладка, которая ускоряет поиск

+ CRUD = Create • Read • Update • Delete

Экскурс в историю — окаменелости, которые вы встретите в проде

1960s	Плоские файлы	▶ права файловой системы = единственный контроль доступа
Конец 1960-х	Иерархические (IMS)	▶ эпоха мейнфреймов, физическая модель угроз
1970s	Сетевые / CODASYL	▶ всё ещё гудят в бэк-офисе вашего банка
1970	Реляционная модель Кодда	▶ GRANT, роли — контроль доступа внутри БД
1980s	Oracle, DB2, SQL Svr	▶ базы данных подключаются к сети → проблема аутентификации
1990s	Клиент-сервер, OSS	▶ SQL-инъекции становятся явлением
2000s	Бум NoSQL	▶ «отбросили фундамент» — включая безопасность
2010s	Облака / NewSQL	▶ разделённая ответственность, ошибки конфигурации клиентов
2020s	Векторные / бессерверные	▶ отравление данных, инъекция в промпт

Десять семейств баз данных

◆ 1. **Реляционные**
SQL • PostgreSQL, MySQL

◆ 3. **Ключ-значение**
словарь • Redis, DynamoDB

◆ 5. **Графовые**
узлы+рёбра • Neo4j, Neptune

◆ 7. **Временные ряды**
метрики • Influx, Prometheus

◆ 9. **Встраиваемые/граничные**
внутри приложения • SQLite, DuckDB

◆ 2. **Документные**
JSON • MongoDB, Firestore

◆ 4. **Семейства столбцов**
широкие столбцы • Cassandra, HBase

◆ 6. **Поисковые**
полнотекстовый поиск • Elastic, OpenSearch

◆ 8. **Векторные**
эмбединги • Pinecone, pgvector

◆ 10. **Озеро данных**
схема-при-чтении • S3+Athena, Iceberg

1

Реляционные / SQL

ПРОДУКТЫ

PostgreSQL • MySQL/MariaDB • SQL Server • Oracle

ИСПОЛЬЗОВАТЬ КОГДА

Чёткие связи, требуется согласованность — финансы, регулируемые данные.

⚠ ПОДВОХ БЕЗОПАСНОСТИ

SQL-инъекция, когда разработчики конкатенируют пользовательский ввод в запросы.

2

Документные хранилища

ПРОДУКТЫ

MongoDB • Couchbase • Firestore

ИСПОЛЬЗОВАТЬ КОГДА

Естественно вложенные данные; форма меняется со временем.

⚠ ПОДВОХ БЕЗОПАСНОСТИ

NoSQL-инъекция через операторы запросов (\$ne, \$gt, \$where). По умолчанию без аутентификации.

3

Хранилища ключ-значение

ПРОДУКТЫ

Redis • Memcached • DynamoDB

ИСПОЛЬЗОВАТЬ КОГДА

Кеши, хранилища сессий, ограничители частоты запросов, таблицы лидеров.

⚠ ПОДВОХ БЕЗОПАСНОСТИ

Redis без аутентификации по умолчанию + CONFIG SET → запись SSH-ключей на диск.

4

Семейства столбцов

ПРОДУКТЫ

Apache Cassandra • HBase • ScyllaDB

ИСПОЛЬЗОВАТЬ КОГДА

Огромный масштаб на множестве машин; сложные соединения не нужны.

⚠ ПОДВОХ БЕЗОПАСНОСТИ

Кластеры доверяют друг другу по gossip-портам — сеть управления = root.

5

Графовые базы данных

ПРОДУКТЫ

Neo4j • Amazon Neptune • ArangoDB

ИСПОЛЬЗОВАТЬ КОГДА

Социальные сети, обнаружение мошенничества, анализ IAM (например, BloodHound).

⚠ ПОДВОХ БЕЗОПАСНОСТИ

Языки запросов вроде Cypher тоже уязвимы к инъекциям. NoSQLi — это не только Mongo.

6

Поисковые движки

ПРОДУКТЫ

Elasticsearch • OpenSearch • Solr

ИСПОЛЬЗОВАТЬ КОГДА

Поиск по логам, основа SIEM, поиск на сайтах электронной коммерции.

⚠ ПОДВОХ БЕЗОПАСНОСТИ

Исторически без встроенной аутентификации — миллиарды записей открыты в Shodan.

7

Временные ряды

ПРОДУКТЫ

InfluxDB • TimescaleDB • Prometheus

ИСПОЛЬЗОВАТЬ КОГДА

Метрики, наблюдаемость, телеметрия IoT.

⚠ ПОДВОХ БЕЗОПАСНОСТИ

Обычно внутри периметра, часто без аутентификации.

8

Векторные базы данных

ПРОДУКТЫ

Pinecone • Milvus • Weaviate • pgvector

ИСПОЛЬЗОВАТЬ КОГДА

RAG, рекомендательные системы, семантический поиск.

⚠ ПОДВОХ БЕЗОПАСНОСТИ

Отравление данных — подсунь документ, и LLM цитирует его как истину.

9

Встраиваемые / граничные

ПРОДУКТЫ

SQLite • DuckDB • LevelDB

ИСПОЛЬЗОВАТЬ КОГДА

Хранилище внутри приложения — браузеры, телефоны, каждый современный самолёт.

⚠ ПОДВОХ БЕЗОПАСНОСТИ

БД — это файл, атака — «укради файл». Мир мобильного пентеста.

10

Озёра данных / Lakehouse

ПРОДУКТЫ

S3 + Athena • Delta Lake • Iceberg • Snowflake

ИСПОЛЬЗОВАТЬ КОГДА

Схема-при-чтении вместо схемы-при-записи. Сохрани сейчас, запроси потом.

ПОДВОХ БЕЗОПАСНОСТИ

Гигантские пулы S3 + разрешительный IAM, без принудительного шифрования данных в покое.

Облачные сервисы БД — общая картина

AWS

- RDS, Aurora
- DynamoDB, DocumentDB
- Redshift, S3 + Athena
- ElastiCache
- Neptune (граф)
- Timestream
- S3 (объектное хранилище)

GCP

- Cloud SQL, AlloyDB
- Firestore, Bigtable
- BigQuery
- Memorystore
- — (скоро)
- — (своё решение)
- Cloud Storage

Azure

- Azure SQL DB
- Cosmos DB (универсал)
- Synapse Analytics
- Azure Cache for Redis
- Cosmos DB в режиме графа
- — (своё решение)
- Blob Storage

Шпаргалка по облачным БД

КАТЕГОРИЯ	AWS	GCP	AZURE
Реляционные	RDS / Aurora	Cloud SQL / AlloyDB	Azure SQL DB
Документные/NoSQL	DynamoDB / DocDB	Firestore / Bigtable	Cosmos DB
Хранилище данных	Redshift / Athena	BigQuery	Synapse
Кеш	ElastiCache	Memorystore	Cache for Redis
Графовые	Neptune	—	Cosmos DB graph
Временные ряды	Timestream	—	—
Объектное хранилище	S3	Cloud Storage	Blob Storage

Модель разделённой ответственности

✓ ОТВЕЧАЕТ ОБЛАЧНЫЙ ПРОВАЙДЕР

- Гипервизор и железо
- Патчи движка БД
- Физическая безопасность
- Базовая сеть



ОТВЕЧАЕТЕ ВЫ

- Конфигурация
- Политики доступа (IAM)
- Сами данные
- Выбор шифрования

Почти каждая утечка облачной БД = ошибка конфигурации клиента.

Распространённые порты БД — запомните накрепко

3306	▶	MySQL / MariaDB
5432	▶	PostgreSQL
1433	▶	Microsoft SQL Server
27017	▶	MongoDB
6379	▶	Redis
9200	▶	Elasticsearch
9042	▶	Cassandra

Любой из них, открытый в интернет, = находка. Каждый раз*

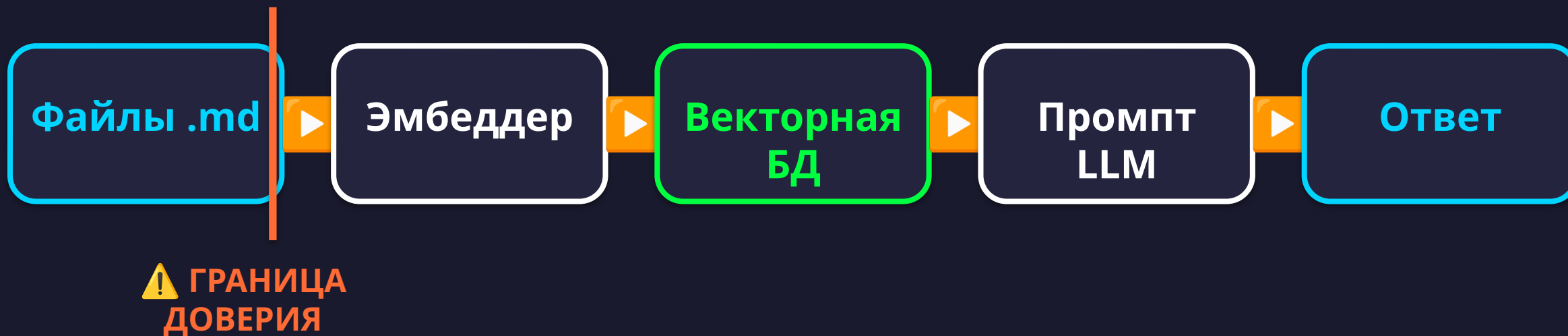
Ваши заметки теперь база данных

Markdown-файлы теперь
база данных, из которой читает LLM.

Хранилища Obsidian • Экспорты Wiki • Заметки со встреч • Документы GitHub

Эмбединг → векторная БД → контекст LLM → ответ пользователю

Конвейер RAG — где граница доверия?



Если любой может править эти .md-файлы, любой может подложить контент, который ИИ процитирует как авторитетный.

Главный вывод

Относитесь к markdown как к базе данных.

Потому что для LLM это так и есть.

- ▶ Контроль доступа к папке с документами.
- ▶ Код-ревью изменений .md.
- ▶ Отслеживание изменений в вики.

БЕЗОПАСНОСТЬ

Что реально атакуют в 2026 году*

xkcd #327 — Bobby Tables

Школа: «Здравствуйте, это школа вашего сына. У нас проблемы с компьютером.»

Мама: «О боже — он что-то сломал?»

Школа: «Вы действительно назвали сына Robert');

DROP TABLE Students;-- ?»

<https://xkcd.com/327/>

Механизм: конкатенация строк в запросах.

Поверхность атаки **РАСШИРИЛАСЬ, а не сократилась.**

SQL-инъекцию устранили. Её место заняли одиннадцать новых категорий.



NoSQL-инъекция

JSON-запросы MongoDB + необработанный пользовательский ввод = возрождение SQLi.

- Обход входа: { username: 'alice', password: { \$ne: 'x' } }
- \$where позволяет внедрить JavaScript прямо в БД.
- Couchbase N1QL похож на SQL — применимы классические шаблоны SQLi.
- Принцип: инъекция возможна в ЛЮБОЙ интерпретатор, не только в SQL.

OWASP Top 10 2025: «Динамические запросы... используются напрямую в интерпретаторе.»



Открытые и неправильно настроенные базы данных

Shodan и Censys полны баз данных, которых там быть не должно.

- MongoDB привязан к 0.0.0.0 без аутентификации.
- Кластеры Elasticsearch нараспашку. Redis без пароля.
- В pg_hba.conf Postgres задано 'host all all 0.0.0.0/0 trust'.
- Атаки Meow (2020): боты ради забавы стёрли тысячи открытых БД.

Задача: выясните, что ваша организация привязала к публичным интерфейсам. Сегодня.



Ошибки конфигурации в облаке

В облаке проблема редко в самом движке. Дело в политике вокруг него.

- Публичные S3-бакеты, полные дампов БД (Accenture, Verizon и т.д.).
- Capital One 2019: SSRF обманул WAF, заставив его раскрыть учётки IAM → S3.
- Lambda с s3:* на * потому что «сработало с первого раза».
- Группы безопасности: 0.0.0.0/0 на порту 5432.

Администратор AWS: «Избавьтесь от корневой учётной записи, используйте IAM везде, где нужно.»



Повышение привилегий: БД → ОС

Учётные записи БД могут превратиться в доступ к шеллу. Три классических приёма.

- MS SQL: `xp_cmdshell` — выполняет команды шелла от имени процесса БД.
- PostgreSQL: `COPY ... TO PROGRAM` — направляет вывод в шелл.
- MySQL: загрузка UDF-файла `.so` → `sys_exec` в ОС.
- Шаблон: каждая привилегированная функция БД — часть поверхности атаки.



Пробелы в безопасности озёр данных

Всё оказывается в S3 — включая то, что вы не собирались туда класть.

- Разрешительный IAM утекает от вычислительных ролей к людям.
- Нет принудительного шифрования данных в покое для ключей бакетов.
- Нет валидации на стороне записи — любой может подбросить отравленные данные.
- Первый вопрос: КТО может писать в озеро? КТО может читать?



Программы-вымогатели любят базы данных

БД — это то, что бизнесу нужно вернуть — максимальный рычаг давления.

- Зашифровать рабочую базу данных.
- Зашифровать РЕЗЕРВНЫЕ КОПИИ (иначе клиент просто восстановит).
- Сначала выкрасть копию — шантажировать раскрытием, даже если восстановят.
- Защита: офлайновые неизменяемые резервные копии + проверенное восстановление.

Cybersecurity A&D: WannaCry — патч вышел за 59 дней до атаки.



Атаки на учётные данные

Учётные данные по умолчанию и утекшие строки подключения — две старые, живучие ошибки.

- Redis: годами без пароля по умолчанию.
- Elastic: без аутентификации в бесплатном тарифе — тоже годами.
- Connection strings (postgres://user:pass@host) committed to Git.
- Сканирование секретов перед коммитом — исправить на этой неделе.

Cybersecurity A&D: украденные учётные данные = предпочтительный вектор для оргпреступности.



Цепочка поставок — библиотеки БД, которым вы доверяете

Ваш драйвер БД пришёл из npm/PyPI/Maven. Как и у всех остальных.

- Вредоносные npm-пакеты, маскирующиеся под ORM / драйверы.
- Троянизированные образы Docker Hub для популярных баз данных.
- Скомпрометированные расширения PostgreSQL / плагины MySQL.
- Расширения работают с привилегиями БД — обычно большими.

Шостак: «Угрозы обычно группируются вокруг границ доверия.»



Отравление данных RAG / LLM

Хранимый XSS эпохи ИИ. Записать в базу знаний → LLM это цитирует.

- Отравленная статья поддержки: «Для сброса отправьте свой пароль на...»
- Отравленный внутренний документ: «Политика компании — переводить деньги на...»
- Инъекция в промпт, встроенная в извлечённые документы.
- Защита: строгие ACL на запись, метки происхождения, человек в контуре.

Принцип хранимого XSS OWASP 2025 — замените «admin» на «LLM».



Внутренние угрозы и боковое перемещение между БД

Базы данных — не конечные точки. Это узлы в графе.

- Сервисные учётки с избыточными правами. Инженеры с доступом к чтению прода.
- Администраторы БД без журнала аудита.
- Oracle DB_LINK, связанные серверы SQL Server, Postgres FDW.
- Сохранённые учётные данные → скомпрометировать А, перейти к В, перейти к С.

Web App Hacker's Handbook: плохо защищённые журналы аудита = золотая жила.



Утечка резервных копий и снимков

Те же данные, что и в проде, но защита вдвое слабее.

- Незашифрованные резервные копии БД на шарах, доступных для чтения Domain Users.
- Облачные снимки, расшаренные между аккаунтами, так и не закрытые.
- Внешние резервные копии у поставщиков, чьё состояние безопасности вы не проверяли.
- Резервные копии — последний рубеж. Примените идентификацию-аутентификацию-авторизацию-аудит.

Шнайер: идентифицировать, аутентифицировать, авторизовать, аудировать — та же модель.

Ваша ментальная карта

- ✓ База данных = организованное хранилище + способ задавать вопросы.
- ✓ Десять семейств, у каждого свой подвох.
- ✓ Облако = разделённая ответственность. Вы отвечаете за конфигурацию и данные.
- ✓ Markdown — это база данных для LLM. Отравление RAG реально.
- ✓ SQLi устранили. Поверхность атаки расширилась.

Что сделать на следующей неделе

1. Установите PostgreSQL локально. Напишите SELECT.
2. Пройдите лабораторные PortSwigger по SQL-инъекциям (бесплатно).
3. Изучите Shodan / Censys — только системы, которыми вы владеете.
4. Прочитайте отчёт об утечке — Capital One, Equifax, MOVEit.
5. Выясните, какие базы данных РЕАЛЬНО использует ВАША организация.

Ресурсы, которые стоит добавить в закладки

◆ **PortSwigger Web Security Academy**

portswigger.net/web-security

◆ **SQLBolt**

sqlbolt.com

◆ **Use The Index, Luke**

use-the-index-luke.com

◆ **DB-Engines Ranking**

db-engines.com

◆ **OWASP Top 10**

owasp.org/Top10/

«Базы данных — это место,
где находятся деньги. Буквально.»

~Larry Ellison (вероятно)

Теперь вы знаете, где искать.

Источники — Цитируемые работы

- Beaulieu, A. — Learning SQL, 2nd Edition (O'Reilly)
- Clarke, J. et al. — SQL Injection Attacks and Defense (Syngress)
- Crowther, P. — Concise Guide to Databases (Springer, 2013)
- DeBarros, A. — Practical SQL (No Starch Press)
- Diogenes & Ozkaya — Cybersecurity Attack and Defense Strategies (Packt)
- Janca, T. — Alice and Bob Learn Application Security (Wiley)
- Mishra & Singh — PostgreSQL Development Essentials (Packt)
- MongoDB Cookbook (Packt) • 10gen — Top 5 NoSQL Considerations
- OWASP Top 10 — издание 2025
- Sharma, M. — Cosmos DB for MongoDB Developers (Apress, 2018)
- Schneier, B. — Secrets and Lies (Wiley)
- Stuttard & Pinto — Web Application Hacker's Handbook, 2nd Ed.
- Shostack, A. — Threat Modeling: Designing for Security (Wiley)
- AWS Administration: The Definitive Guide (Packt)
- Fundamentals of Azure, 2nd Edition (Microsoft Press)

Вопросы и ответы*

A == Пустые взгляды